

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

ISO/IEC 27001:2022 " ISO/IEC 27002:2022

**** ISMS práctico, riesgos, auditorías, controles y herramientas de código abierto****

Un manual de trabajo para administradores, analistas junior, estudiantes, cambiadores de carrera, auditores internos y equipos de seguridad

Alberto (Al) Leiva

Primera edición • Julio 2026

Inside: Cláusulas 4–10 • todos los 93 controles del Anexo A • riesgo • Declaración de aplicabilidad • auditoría • certificación • evidencia • herramientas • laboratorios • preparación de la carrera |

|. |

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Este manual educativo independiente no es una publicación ISO, asesoría legal, decisión de certificación, informe de auditoría o sustituto de las normas ISO/IEC licenciadas. Las publicaciones ISO tienen derechos de autor. Las descripciones de control y cláusulas aquí son resúmenes originales; use las normas oficiales para requisitos y orientación exactos.

ISO desarrolla estándares pero no certifica organizaciones. La certificación es opcional y es realizada por los organismos de certificación. Verifique la acreditación, alcance, ubicación, versión y estado de certificado antes de confiar en una reclamación de certificación.

Uso ético y autorizado

Utilice herramientas técnicas únicamente en sistemas, aplicaciones, redes, cuentas de nube, repositorios y datos que posee o está específicamente autorizado por escrito para evaluar. Use datos sintéticos y sistemas aislados en laboratorios.

Prefacio

Una introducción práctica a la gestión de la seguridad de la información y las garantías basadas en pruebas.

ISO/IEC 27001 es una norma de requisitos para establecer, aplicar, mantener y mejorar continuamente un sistema de gestión de la seguridad de la información. Utiliza la gestión del riesgo para preservar la confidencialidad, la integridad y la disponibilidad de una manera que se ajuste a la organización. ISO/IEC 27002 proporciona orientación de control detallada pero no es en sí mismo un estándar de certificación.

Las ediciones base actuales son ISO/IEC 27001:2022 y ISO/IEC 27002:2022. ISO/IEC 27001:2022 La enmienda 1:2024 añade un examen explícito del cambio climático al contexto organizativo y observa que las partes interesadas pueden tener requisitos relacionados con el clima. La enmienda no significa que cada organización debe crear un programa climático; debe hacer y apoyar una determinación razonada de relevancia dentro del contexto ISMS.

Un ISMS exitoso no es una carpeta de políticas. Es un sistema de gestión funcional: los líderes establecen dirección, los propietarios de riesgos toman decisiones de tratamiento informadas, los equipos operan controles, las pruebas de auditoría interna del sistema, los resultados de los exámenes de gestión y la acción correctiva evita la recurrencia.

Cómo utilizar este manual

Los administradores deben comenzar con los Capítulos 1–5 y 18–23.

Los analistas juniores deben estudiar cláusulas, temas del anexo A, pruebas de evidencia, herramientas, laboratorio y preparación de entrevistas.

Los auditores internos deben centrarse en criterios objetivos, independencia, poblaciones completas, muestreo, conclusiones, medidas correctivas y seguimiento.

Las organizaciones que solicitan la certificación deben confirmar las normas, enmiendas, alcance de certificación y expectativas de acreditación con los profesionales competentes.

Contenido de la palabra:** Este documento contiene un campo de mesa de contenido de Word nativo y una guía de capítulo verificada. Después de editar, haga clic con el botón derecho en el contenido y elija el campo de actualización, luego actualice la tabla completa. |. |

Tabla de contenidos

[Notificación de publicación y uso \[2\]\(#publication-and-use-notice\)](#)

[Uso electrónico y autorizado \[2\] \(#ethical-and-authorized-use\)](#)

[Prefacio \[3\] \(#preface\)](#)

[Cómo utilizar este manual \[4\]\(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[4\]\(#table-of-contents\)](#)

[1. ISO/IEC 27001 y 27002 Foundations \[7\]\(#isoiec-27001-and-27002-foundations\)](#)

[2. ISMS Scope and Interested Parties \[8\]\(#isms-scope-and-interested-parties\)](#)

[3. Evaluación del riesgo y tratamiento del riesgo \[9\]\(#risk-assessment-and-risk-treatment\)](#)

4. Declaración de aplicabilidad [10](#statement-of-applicability)
5. Documentación y pruebas [11](#documentation-and-evidence)
6. Cláusula 4 — Contexto de la organización [12](#clause-4-context-of-the-organization)
7. Cláusula 5 — Liderazgo [13](#clause-5-leadership)
- [8. Cláusula 6 — Planificación [14] (#clause-6-planning)] (#clause-6-planning)
9. Cláusula 7 - Apoyo [15](#clause-7-support)
- [10. Cláusula 8 — Operación [16] (#clause-8-operation)] (#clause-8-operation)
11. Cláusula 9 — Evaluación del desempeño [17](#clause-9-performance-evaluation)
12. Cláusula 10 — Mejora [18](#clause-10-improvement)
13. Anexo A 5 Controles de organización [19](#annex-a-5-organizational-controls)
14. Anexo A 6 Controles de personas [22](#annex-a-6-people-controls)
15. Anexo A 7 Controles físicos [23](#annex-a-7-physical-controls)
16. Anexo A 8 Controles tecnológicos [24](#annex-a-8-technological-controls)
17. Implementing Controls with ISO/IEC 27002 [26](#implementing-controls-with-isoiec-27002)
18. Pruebas de medición y control [27](#metrics-and-control-testing)
19. Auditoría interna [28](#internal-audit)
20. Management Review and Corrective Action [29](#management-review-and-corrective-action)
21. Lectura de certificación [30](#certification-readiness)
22. Herramientas de código abierto [31](#open-source-tools)
 - 22.1 Auxiliar de CISO [31](#ciso-assistant)
 - 22.2 Comunidad SimpleRisk [31](#simplerisk-community)
 - 22.3 Wazuh [31](#wazuh)
 - 22.4 osquery [32](#osquery)
 - 22.5 OpenSCAP [32](#openscap)
 - 22.6 Greenbone Community Edition [32](#greenbone-community-edition)
 - 22.7 Nmap [32](#nmap)
 - 22.8 Trivy [32](#trivy)

22.9 OWASP ZAP [33](#owasp-zap)

22.10 Keycloak [33](#keycloak)

22.11 DefectDojo [33](#defectdojo)

22.12 AIDE [33](#aide)

22.13 Lynis [33](#lynis)

22.14 Agente de política abierta [33](#open-policy-agent)

23. Manual del SGSI para gerentes [35](#managers-isms-playbook)

24. Guía de la carrera de analista junior [36](#junior-analyst-career-guide)

24.1 Trabajo junior típico [36](#typical-junior-work)

24.2 Valor de los empleadores de habilidades [37](#skills-employers-value)

25. Laboratorio de Ficción y Cartera [38](#fictional-laboratory-and-portfolio)

26. Plan de aprendizaje de 30 días [39] (#thirty-day-learning-plan)

27. Preparación de entrevistas [40](#interview-preparation)

27.1 ¿Qué es un ISMS? [40](#what-is-an-isms)

27.2 ISO 27001 versus 27002? [40](#iso-27001-versus-27002)

27.3 ¿Cuál es el SoA? [40](#what-is-the-soa)

27.4 ¿Todos los controles del anexo A son obligatorios? [40](#are-all-annex-a-controls-mandatory)

27.5 ¿Cómo se prueba un control? [40](#how-do-you-test-a-control)

27.6 ¿Qué es una no conformidad? [40](#what-is-a-nonconformity)

27.7 ¿Qué cambió en 2024? [40](#what-changed-in-2024)

27.8 ¿Qué puede concluir un analista junior con seguridad? [40](#what-can-a-junior-analyst-safely-conclude)

27.9 Preguntas para hacer al empleador [40](#questions-to-ask-the-employer)

28. Plantillas, Glosario, Índice y Referencias [42](#templates-glossary-index-and-references)

28.1 Registro mínimo de riesgo [42](#minimal-risk-record)

28.2 Documentos de prueba de control [42](#control-test-workpaper)

28.3 Glosario [42](#glossary)

28.4 Índice de asunto [43](#subject-index)

1. ISO/IEC 27001 y 27002 Foundations

Ediciones actuales, propósito, relación y limitaciones importantes.

Jim src="media/image1.png" style="width:6.15in;height:3.39605in" alt="Context and risk drive planning, implementation, evaluation, and improvement." /

Gráfico 1 Ciclo de mejora continua de los ISMS

** Documentos** | **

|

La vida eterna... | | ISO/IEC 27001:2022 | Requisitos de ISMS normativos, incluyendo el Anexo Un control de referencia ANTE LAS ORGANIZACIONES pueden ser certificados | ISO/IEC 27001:2022/Amd 1:2024 | Cambios climáticos que afectan el contexto y la consideración de los interlocutores interesados | Aplicado con el estándar base permanente | ISO/IEC 27002:2022 | Orientación para la aplicación de los controles de seguridad de la información | ISO/IEC 27005:2022 Silencioso Guía para la gestión del riesgo de seguridad de la información | Orientación de apoyo, no el estándar de certificación 27001

- Las cláusulas 4-10 contienen requisitos que una organización debe abordar para su conformidad.
- En el anexo A se enumeran 93 controles de referencia en cuatro temas: 37 orgánicos, 8 personas, 14 físicos y 34 tecnológicos.
- La selección de control sigue el tratamiento de riesgos y las obligaciones aplicables; el anexo A no es una lista de verificación universal en la que siempre debe aplicarse cada control.
- La Declaración de aplicabilidad registra los controles necesarios, la justificación, el estado de aplicación y las exclusiones justificadas del anexo A.

2. ISMS Scope and Interested Parties

Cómo definir un límite defensible para el sistema de gestión.

- Identificar objetivos comerciales, productos, servicios, procesos, información, entidades jurídicas, lugares, personas, proveedores, tecnologías y dependencias.
- Comprender las cuestiones internas pertinentes, como la estrategia, la cultura, las aptitudes, la arquitectura, la gobernanza y los recursos.
- Comprender cuestiones externas relevantes como amenazas, leyes, contratos, mercados, proveedores, condiciones físicas y cambio tecnológico.

- Determinar las partes interesadas y los requisitos pertinentes, incluidos los clientes, reguladores, trabajadores, propietarios, proveedores, comunidades y partes interesadas en la certificación.
- Considerar si el cambio climático es relevante para la eficacia del SIV y si las partes interesadas tienen requisitos relacionados con el clima; documentar el razonamiento.
- Definir límites de alcance, interfaces, exclusiones, dependencias y justificación en lenguaje que pueda ser auditado.
- Mantenga el alcance alineado con los inventarios de activos, procesos, red, nube, proveedor y flujo de datos.

Silencioso ** Prueba de la encuesta** |. | ¿Qué entidades jurídicas, sitios, servicios, procesos y tecnología están incluidas? | Declaración y mapas aprobados del alcance | INTERCAMBIO | ¿Qué conecta el alcance con otros equipos, sistemas, proveedores y ubicaciones? flujos de datos, arquitectura, contratos, matriz de responsabilidad ¿Podría ocultarse información importante o riesgo fuera del límite establecido? | Reconocimiento de inventarios y descubrimientos | ¿Qué desencadena una revisión de alcance? | Cambio de registros, adquisiciones y puertas de producto | ¿Podrían los efectos climáticos o las expectativas de los interesados afectar a la disponibilidad, proveedores, instalaciones, personas o obligaciones? | Análisis de contexto, decisión, acciones cuando sea relevante

3. Evaluación de riesgos y tratamiento de riesgos

Un método repetible que conecta el riesgo empresarial para controlar las decisiones.

El estilo “png”=“width:6.15in;height:3.39605in” alt=“Los dueños de Risk evalúan escenarios, tratamiento y riesgo residual utilizando criterios definidos”.

Gráfico 2 Corriente de trabajo sobre el riesgo de seguridad de la información

Definir los criterios de riesgo antes de anotar: método de identificación de riesgos, escalas de probabilidad y consecuencias, reglas de cálculo, umbrales de aceptación, tratamiento requerido, escalada, frecuencia de revisión y autoridad propietaria de riesgos. Aplicar el método lo suficientemente consistente para producir resultados válidos y comparables.

Field |**

|... | TEN ASO o objetivo ANTERI Portal del cliente y disponibilidad requerida contractualmente | Amenaza evento | Credencial robo seguido de acceso administrativo no autorizado TEN Vulnerability or condition – Inscripción débil y no MFA resistente al phishing – Consecuencias tención Controles existentes TEN MFA, acceso condicional, registro, verificación de apoyo | tención Riesgo hereditario o actual tención Puntaje usando criterios de probabilidad y consecuencia aprobados | tóxico Modificar el riesgo mediante una autenticación más fuerte y la recuperación monitoreada | | Propietario y fecha | Nombrado responsable del riesgo y fecha de destino – Riesgo Residual | Reassess after treatment; obtain explicit owner approval |

4. Declaración de aplicabilidad

El puente entre el tratamiento del riesgo, el anexo A, otros controles y pruebas de auditoría.

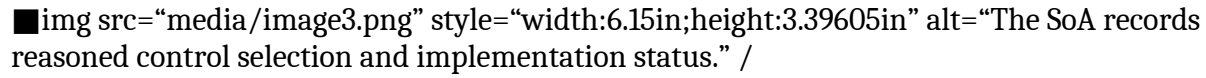
■  src="media/image3.png" style="width:6.15in;height:3.39605in" alt="The SoA records reasoned control selection and implementation status." /

Figure 3. Statement of Applicability workflow

- List the controls necessary to treat identified information-security risks and meet legal, regulatory, contractual, and business requirements.
- No se pasan por alto los controles seleccionados del anexo A.
- Recordar si cada control del Anexo A es aplicable y justificar la inclusión o exclusión.
- Recordar claramente el estado de aplicación y mantenerlo en consonancia con el plan de tratamiento de riesgos y las pruebas de funcionamiento.
- Incluir controles específicos de la organización cuando el anexo A no se ocupa plenamente de un riesgo.
- Controlar el SoA como información documentada y actualizarla después de cambios de riesgo, alcance, legal, proveedor, tecnología o control.

Control Silencioso ** Aplicable |**

|. | | Ejemplo 8.15 logging | Sí | Necesitado para la detección, la investigación y las obligaciones TEN Aplicado con acciones abiertas TEN Operaciones de Seguridad / inventario de fuentes y registros de revisión – Ejemplo 7.9 activos fuera de locales | Sí | Personal remoto y de viaje utilizan dispositivos de empresa – Operaciones de TI aplicadas / inventario y prueba de encriptación Por ejemplo, control de la organización | Sí | El riesgo específico de seguridad de productos requiere versiones firmadas | Implementado parcialmente | Ingeniería / archivos de tuberías Por ejemplo, la exclusión La tecnología descrita o el escenario está ausente del alcance controlado TEN No aplicable ANTES Ámbito de estudio y evidencia de arquitectura

5. Documentación y evidencia

Cómo mantener información documentada útil sin crear burocracia.

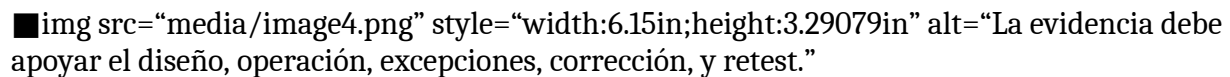
■  src="media/image4.png" style="width:6.15in;height:3.29079in" alt="La evidencia debe apoyar el diseño, operación, excepciones, corrección, y retest." /

Figure 4. Requirement-to-evidence chain

Documento o registro | Purpose | ** Controles de control**

La vida... la vida... la vida... la vida... la vida... tención ISMS scope | Define los límites e interfaces | Aprobado, actual, coherente con la realidad | Silencioso | Establece dirección y compromisos tención método de riesgo y registro | Muestra evaluación y decisiones repetibles

– Criterios aplicados consistentemente; los propietarios aprueban el riesgo residual Plan de tratamiento de riesgo | Pistas acciones, propietarios, recursos y fechas | SONAL a riesgos y SoA | tención Declaración de aplicabilidad | Explica selección de control y estatus | Todos los controles del Anexo A abordados; justificaciones apoyadas TENCIÓN Objetivos y métricas TENENCIA Mostrar resultados planificados y evaluación – Competencia y registros de conciencia | Apoyo a la capacidad y la comprensión | Pruebas operativas | Shows controles realmente operados | Completa, auténtica, protegida, retenida tención auditiva y registros de revisión tención apoya la supervisión y las decisiones | Correctiva-action records | Shows root cause and effective correction TEN Cause addressed, recurrence considered, effectiveness verified |

Cláusula 4 - Contexto de la organización

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

**** Objetivo de uso:** Contexto de la organización |

|. |

Cláusula

tención 4.1 tención Entender las cuestiones internas y externas que pueden afectar al ISMS; considerar explícitamente si el cambio climático es relevante. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. tención 4.2 tención Identificar a las partes interesadas pertinentes, sus requisitos, y si incluyen expectativas relacionadas con el clima. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. tención 4.3 | Definir y mantener el alcance de ISMS, incluyendo límites, interfaces, dependencias, ubicaciones, tecnología y exclusiones. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. tención 4.4 | Establecer, operar, mantener y mejorar continuamente el ISMS y sus procesos necesarios. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

TEN 2024 enmienda: Determinar explícitamente si el cambio climático es relevante para el contexto del SIV y reconocer que las partes interesadas pertinentes pueden tener requisitos relacionados con el clima. Mantenga la evidencia del razonamiento y cualquier acción resultante. Respuesta

7. Cláusula 5 - Liderazgo

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

Propósito de uso: Liderazgo | |

Cláusula

tención 5.1

TEN 5.2

TEN 5.3

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

8. Cláusula 6 - Planificación

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

**** Objetivo de uso:** ** Planificación domiciliaria |

|... |

Cláusula

tención 6.1.1

tención 6.1.2

TEN 6.1.3

6.2

tención 6.3 Silencioso Plan ISMS cambia para que se tengan en cuenta sus propósitos, consecuencias, recursos, responsabilidades e integridad del sistema. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

9. Cláusula 7 - Apoyo

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

**** Objetivo de uso:** ** Apoyo a la prevención |

|... |

Cláusula

tención 7.1

tención 7.2

tención 7.3

TEN 7.4

7.5

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

Cláusula 8 - Operación

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

**** Objetivo de uso:** ** Operación confidencialidad |

|... |

Cláusula | Significado claro | Enfoque de verificación | Evidencia de ejemplo |

|

----- La vida eterna... | TEN 8.1 |

Plan y control ISMS procesos, criterios, cambios, trabajo subcontratado y evidencia de una operación adecuada. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. TEN 8.2 | Realizar evaluaciones de riesgos de seguridad de la información a intervalos previstos y cuando se producen cambios significativos. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. TEN 8.3
TENCIÓN Aplicar el plan de tratamiento de riesgos y mantener evidencia de resultados. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

•

11. Cláusula 9 - Evaluación del desempeño

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

**** Objetivo de uso:** ** Evaluación de la actuación profesional |

|... |

Cláusula

tención 9.1

tención 9.2.1

TEN 9.2.2 TUR Mantener un programa de auditoría con frecuencia, métodos, responsabilidades, planificación, presentación de informes, alcance, criterios, auditores objetivos, resultados retenidos y medidas correctivas oportunas. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. TEN 9.3.1 | La gestión revisa el ISMS a intervalos previstos para la idoneidad, adecuación y eficacia continuas. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. tención 9.3.2 tención Revisión requiere insumos como acciones anteriores, cambios de contexto, necesidades de las partes interesadas, rendimiento, retroalimentación, riesgo, tratamiento y oportunidades de mejora. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. tención 9.3.3 | Reseña de decisiones de gestión de registros sobre mejoras y cambios necesarios del ISMS. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

Un programa de auditoría sigue el riesgo, la independencia, la evidencia, el reporte y el seguimiento verificado.

Gráfico 5 Corriente de trabajo de auditoría interna

Cláusula 10 - Mejora

Requisitos de idiomas, enfoque de verificación y pruebas de ejemplo.

**** Objetivo de uso: **** Mejora de la vida |

|. |

Cláusula

TEN 10.1 TENCIÓN Continuarmente mejorar la idoneidad, la adecuación y la eficacia del ISMS. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento. TEN 10.2 TENCIÓN Reaccionar a noconformidades, corregirlas, analizar causas, prevenir la recurrencia, verificar la eficacia y retener evidencia. tención Confirme la propiedad, alcance, método, aprobación, pruebas de funcionamiento, excepciones, corrección y registros retenidos. – Políticas, registros, planes, registros, actas, minutos, resultados, aprobaciones y pruebas de seguimiento.

Utilice el texto oficial licenciado ISO/IEC 27001 para requisitos normativos exactos. Este manual parafrasea conceptos para la educación y no reemplaza el estándar.

“Los 93 controles de referencia se agrupan en temas organizativos, de personas, físicos y tecnológicos.” / título

Gráfico 6 Temas de control del anexo A

13. Anexo A 5 Controles de organización

- Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de pruebas*.

Control | ** Significado práctico** | ** Enfoque de la verificación**

La inmortalidad

----- La inmortalidad- tención 5.1 | Mantener políticas aprobadas de seguridad de la información. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | tención 5.2 | Definir las funciones y responsabilidades de seguridad. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.3 TENIENDO deberes conflictivos separados. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.4 | Exigir a los administradores que cumplan las responsabilidades de seguridad. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.5 | Mantener contacto adecuado con las autoridades. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.6 | Participar en grupos de seguridad relevantes y foros profesionales. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.7 | Recoge y usa inteligencia de amenazas. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.8 | Construir la seguridad en la gestión de proyectos. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.9 | Información sobre inventarios y activos asociados. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.10 | Definir reglas aceptables de uso y manejo. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | tención 5.11 | Recuperar los activos organizativos cuando las funciones terminan o cambian. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.12 | Clasificación de la información según necesidad y riesgo. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. |

Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.13 | Información de la etiqueta consistente con la clasificación. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.14 | Proteger las transferencias de información. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.15 | Establecer reglas de control de acceso. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | tención 5.16 – Administrar las identidades a lo largo de su ciclo de vida. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.17 | Proteger información de autenticación. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.18 | Aprobar, revisar, modificar y eliminar los derechos de acceso. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.19 | Manage security risk in provider relations. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.20 | Incluye requisitos de seguridad en los acuerdos de proveedores. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.21 | Manage ICT supply-chain security risk. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.22 Silenciosos Monitor, revisión y control de cambios de servicio de proveedores. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.23 | Govern adquisición, uso, gestión y salida de servicios en la nube. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.24 | Preparar y planificar para la gestión de incidentes de seguridad. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.25 | Evaluar los acontecimientos y decidir si son incidentes. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.26 | Responder a incidentes de seguridad. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.27 | Aprende de incidentes y mejora los controles. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.28 | Identificar, recolectar, adquirir y preservar evidencia. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.29 | Proteger la información durante la interrupción. TEN Confirmar riesgo o obligación, diseño,

propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.30 | Preparar las TIC para apoyar la continuidad de las operaciones. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.31 | Identificar y cumplir con los requisitos legales, regulatorios y contractuales. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.32 | Protege los derechos de propiedad intelectual. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 5.33 | Protege los registros durante su ciclo de vida. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.34 | Protege la privacidad y la información personal identificable. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.35 | Organizar exámenes independientes de la seguridad de la información. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.36 | Comprobar el cumplimiento de las políticas, reglas y estándares de seguridad. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 5.37 | Mantener procedimientos operativos documentados. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. |

- Regla de la sesión* El anexo A es un conjunto de referencia utilizado para comprobar que no se pasaron por alto los controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante tratamiento de riesgo y registrarse en la Declaración de aplicabilidad. | |.

img src="media/image7.png" style="width:6.15in;height:3.29657in" alt="Prepare, evalúe, responda, preserve evidencia y aprenda de incidentes." /

Figure 7. Security-incident management

14. Annex A 6 People controls

- Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de pruebas*.

Control | ** Significado práctico** | ** Enfoque de la verificación**

La inmortalidad

----- TEN 6.1 TENCIÓN A los candidatos y personal de la pantalla según la ley, el papel y el riesgo. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | tención 6.2 | Incluye responsabilidades de seguridad en términos de empleo. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | tención 6.3 | Proporcionar conciencia, educación y formación continua basada en el papel. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 6.4 | Opera un proceso disciplinario justo y comunicado. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 6.5 | Administrar las obligaciones de seguridad después de la terminación o cambio de roles. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | TEN 6.6 | Utilizar acuerdos adecuados de confidencialidad o no divulgación. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 6.7 | Proteger la información durante el trabajo a distancia. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. | | 6.8 | Hacer que la información de los eventos de seguridad sea fácil y oportuna. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición. | Procedimiento, configuración, registro, registro, ticket, revisión, test o observación. |

- Regla de la sesión* El anexo A es un conjunto de referencia utilizado para comprobar que no se pasaron por alto los controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante tratamiento de riesgo y registrarse en la Declaración de aplicabilidad. | |.

15. Anexo A 7 Controles físicos

- Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de pruebas*.

Control

TEN 7.1 TENCIÓN Definir y proteger los perímetros de seguridad física. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición.

TEN 7.2

7.3

tención 7.4 Silenciosos Supervisar locales para el acceso físico no autorizado. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición.

7.5

tención 7.6

7.7

TEN 7.8

Control

tención 7.9

7.10

7.11

7.12

7.13

7.14

- Regla de la sesión* El anexo A es un conjunto de referencia utilizado para comprobar que no se pasaron por alto los controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante tratamiento de riesgo y registrarse en la Declaración de aplicabilidad. | |.

16. Anexo A 8 Controles tecnológicos

- Resúmenes originales de los controles de referencia, el enfoque de verificación y los ejemplos de pruebas*.

Control

TEN 8.1 TENCIÓN Dispositivos de extremo de usuario seguros. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición.

8.2

8.3

8.4

8.5

8.6

8.7

tención 8.8

8.9

8.10

8.11

8.12

8.13

8.14

8.15

tención 8.16

8.17

8.18

tención 8.19

8.20

8.21

8.22

Control

tención 8.23

TEN 8.24

8.25

8.26

8.27

TEN 8.28

TEN 8.29

8.30

TEN 8.31 Ø Medios de desarrollo, ensayo y producción separados. TEN Confirmar riesgo o obligación, diseño, propietario, implementación, operación, excepciones y medición.

8.32

8.33

TEN 8.34

- Regla de la sesión* El anexo A es un conjunto de referencia utilizado para comprobar que no se pasaron por alto los controles necesarios. La organización puede necesitar otros controles. Toda inclusión o exclusión debe justificarse mediante tratamiento de riesgo y registrarse en la Declaración de aplicabilidad. | |.

17. Controles de implementación con ISO/IEC 27002

Cómo convertir las decisiones de riesgo en controles que se ajusten a la organización.

1. Comience con la decisión, obligación y resultado esperado del tratamiento de riesgos, no con una herramienta.
2. Use ISO/IEC 27002 guía y atributos pertinentes para comprender el propósito, las consideraciones de aplicación y las relaciones.
3. Adaptar el control a las personas, procesos, tecnología, entorno físico, limitaciones legales y operaciones empresariales.
4. Definir propietario, alcance, disparador, entradas, pasos, salidas, registros, frecuencia, dependencias, excepciones y escalada.
5. Evaluar si el diseño alcanzaría razonablemente el resultado previsto.
6. Aplicar mediante cambios controlados y capacitar a las personas afectadas.
7. Medir el funcionamiento y la eficacia, investigar excepciones y mejorar.
8. Actualizar riesgos, plan de tratamiento, SoA, procedimientos y evidencia cuando el control cambia.

Distinción importante: ISO/IEC 27002 proporciona orientación. La organización sigue siendo responsable de seleccionar y diseñar controles que traten sus riesgos y cumplan los requisitos aplicables. | |.

18. Pruebas de medición y control

Cómo verificar si el ISMS y sus controles funcionan.

Area | Población y muestra | **

La vida eterna ————— La vida – Todos los riesgos actuales; muestra artículos altos, cambiados, aceptados y atrasados – Reperform scoring, trazo tratamiento, confirma la aprobación del propietario y revisión ANTERI Método, registro, aprobaciones, tratamiento y riesgo residual | | Toda la fuerza de trabajo, privilegio, servicio e identidades de terceros Necesidades, aprobación, MFA, revisión, cambio, inactividad y rescisión del examen ANTERI Población, exportaciones, entradas, ajustes y registros | TEN Vulnerabilities TEN Todos los activos y hallazgos TENCION Validar cobertura, priorización, excepciones, plazos, corrección y rescate ANTERIED Inventory, escaneos, tickets, aprobaciones y retests ANTE | Proveedores | Población completa de proveedores; muestre servicios críticos y cambiados | Testear la diligencia debida, acuerdo, responsabilidad, monitoreo, incidente y salida | | Incidents | Todos los eventos e incidentes denunciados | Evaluación de pruebas, respuesta, evidencia, comunicaciones, recuperación y aprendizaje | Casos, cronología, decisiones, registros de pruebas y lecciones | Continuidad | Procesos críticos y apoyo TIC | Trace negocio necesita para el diseño de recuperación y ejercicios TEN BIA, planes, registros de pruebas, lagunas y retests | TENCION FORMULARIOS | Todos los objetivos y medidas del ISMS ANTERI Consultar definición, calidad de los datos, tendencia, objetivo, análisis, decisión y acción | definiciones métricas, datos fuente, tableros de datos, minutos y acciones

- Definir criterios exactos, alcance, período, población, control, propietario, evidencia y resultados esperados.
- Evaluar el diseño antes de la operación de prueba.
- Obtener la población completa y validar su integridad y exactitud independientemente.
- Seleccione una muestra basada en el riesgo que cubra las fechas, propietarios, ubicaciones, fallos, excepciones y cambios pertinentes.
- Inspeccionar registros, observar el trabajo, entrevistar personal, examinar la configuración y repercutir cuando sea práctico.
- Excepciones de documentos como hechos vinculados a criterios; no exageren ni escondan limitaciones.
- Corrección de la asignación, análisis de la raíz, propietario, fecha prevista, protección provisional y escalada.
- Repueba y declara la conclusión final y la limitación restante.

19. Auditoría interna

- Una evaluación independiente de la conformidad y la aplicación efectiva*.

Mantener un programa de auditoría que considere la importancia del proceso, el cambio, el riesgo y los resultados anteriores.

Definir objetivos, alcance, criterios, calendario, método, muestreo, registros y presentación de informes para cada auditoría.

Select auditors who are competent and sufficiently objective; auditors should not audit their own work without safeguards.

Utilice las normas, requisitos de organización, decisiones de riesgo, SoA, políticas y obligaciones aplicables como criterios.

Registre la evidencia y los hallazgos con suficiente claridad para que otra persona competente pueda comprender el fundamento.

Report results to relevant management and track corrections and corrective actions through effectiveness review.

Tipo de encuentro

Silencioso Conformidad

TEN Oportunidad para la mejora TENENCIA Una sugerencia de mejora útil que no es una noconformidad oculta TENEvaluar voluntariamente y dejar constancia de la decisión – Noconformidad | Uno o más requisitos no se cumplen – Correct, analice la causa, actúe para prevenir la recurrencia y verificar la eficacia Limitación de la auditoría permanente, pruebas, tiempo, independencia o acceso restringidos la conclusión TEN Disclose claramente y resuelva cuando sea posible

20. Management Review and Corrective Action

- Decisiones de liderazgo que mantienen el ISMS adecuado y efectivo.*

Management-review input Questions |**

|. | | Anterior acciones | ¿Se completaron y efectivas decisiones previas? | Context y partes interesadas | ¿Qué cambio, incluyendo la relevancia climática y las necesidades de los interesados? Ø Rendimiento permanente ¿Qué muestran las métricas, los objetivos, los incidentes, los resultados de auditoría y las noconformidades? – Comentarios de las partes interesadas ¿Qué informan los clientes, reguladores, trabajadores, proveedores y propietarios? | Riesgo y tratamiento | ¿Son los niveles de riesgo, aceptación, tratamiento, recursos y SoA todavía apropiados? Las oportunidades de mejora de la vida útil ¿Qué cambios deben aprobar el liderazgo?

- Contener o corregir el problema inmediato.
- Determinar el alcance y si existen fallos similares en otros lugares.

Analyze root cause using evidence, not blame.

- Plan de acción proporcional al efecto y al riesgo de recurrencia.
- Realizar cambios en materia de propiedad y fechas debidas.
- Verificar la eficacia utilizando pruebas definidas después de tiempo suficiente.
- Actualizar riesgos, controles, documentos, capacitación, objetivos y SoA cuando sea necesario.

21. Certificación

Qué certificación hace, cómo procede generalmente, y lo que no garantiza.

Altura:3.39605in” alt=“La sabiduría es seguida por la evaluación de la certificación y las actividades continuas de vigilancia y renovación.” / Español

Figura 8. Carretera de certificación

La certificación es opcional; las organizaciones pueden implementar ISO/IEC 27001 sin solicitar un certificado.

ISO no realiza certificación. Un órgano de certificación independiente realiza auditorías de certificación.

La acreditación proporciona confianza adicional en la competencia de un órgano de certificación; verificar el alcance de acreditación y certificado pertinente.

La etapa 1 generalmente evalúa la preparación, el alcance, el sistema documentado y la preparación para la auditoría de la ejecución.

La etapa 2 evalúa la aplicación y la eficacia en todo el ámbito definido.

Las actividades de vigilancia y recertificación evalúan la conformidad continua; los detalles deben confirmarse con el órgano de certificación seleccionado y las normas de acreditación.

Un certificado tiene alcance y plazo. No prueba que cada producto es seguro, que no puede ocurrir ningún incidente, o que cada sistema en la empresa está incluido.

**** área de preparación **** |

| ... | TENCIÓN ANTERIVISIÓN Clear, supportable, reflected in real operations and certificate intent | tención de riesgo Ø Método utilizado consistentemente; registro completo; los propietarios aceptan el riesgo residual TEN SoA | Todos los controles del Anexo A abordados; selecciones, exclusiones y estatus apoyados | Controles | Aplicado, operado lo suficiente como para producir pruebas fiables, y medido | TEN Auditoría interna Programa de duración y auditoría completa completa con pruebas objetivas y seguimiento | TENCIÓN TENCIÓN TERRITORIO Respuestas requeridas consideradas y decisiones grabadas | Acción correctiva tención Noconformidades corregidas; causa y eficacia abordadas | TEN-ENDENCIA FORMULADA Climática y requisitos de parte interesada considerados y probados

22. Herramientas de código abierto

- Enlaces oficiales, inicios rápidos seguros, pruebas y limitaciones.*

Herramienta

tención CISO Assistant

tención SimpleRisk Community Silencioso www.simplerisk.com | Wazuh | wazuh.com ANTE SIEM, control de punta, FIM | Silencioso osquery | www.osquery.io | Inventario y consultas | OpenSCAP Silencioso www.open-scap.org Evaluación de la configuración de Linux | | Greenbone Community Edition tención greenbone.github.io – Gestión de la Vulnerabilidad | | Nmap | nmap.org | Activo y descubrimiento de servicios | Trivy | trivy.dev | Código, imagen, dependencia, secreto y la configuración escaneado | OWASP ZAP | www.zaproxy.org ▶ | Keycloak | www.keycloak.org TEN Identidad, MFA, roles y logs ANTE – DefectDojo | www.defectdojo.org | Encontrar admisión y remediación | AIDE | aide.github.io | Control de la integridad de archivos | Lynis | cisofy.com – Seguridad de Linux auditando TEN Open Policy Agent | www.openpolicyagent.org

- Limitación crítica* Las herramientas apoyan controles y pruebas; no seleccionan el tratamiento de riesgo, determinan la conformidad, reemplazan a los auditores competentes o certifican a una organización. Validar cobertura, calidad de los datos, configuración, permisos, actualizaciones y revisión humana. |. |

22.1 CISO Assistant

Propósito: ISMS, riesgos, controles, evidencia. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Implementar en un entorno de prueba aislado; crear un proyecto marco, alcance, registro de riesgos, acciones de tratamiento, propietarios y registros de pruebas.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.2 SimpleRisk Community

Propósito: Registro de riesgos y tratamiento. Proyecto oficial: [ejecutado]SimpleRisk Comunidad efectuada/u contacto](<https://www.simplerisk.com/>)

Inicio rápido seguro: Instalar de forma segura, definir criterios de riesgo, registrar riesgos y propietarios, elegir tratamientos, rastrear las fechas debidas y exportar informes revisados.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.3 Wazuh

Propósito: SIEM, monitoreo de puntos finales, FIM. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Instalar un gestor de laboratorio y agente, confirmar la inscripción, desencadenar un evento de prueba autorizado, revisar la alerta, y preservar la configuración y la evidencia de alerta.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.4 osquery

Propósito: Inventario de punto final y consultas. Proyecto oficial: (<https://www.osquery.io/>)

Inicio rápido seguro: Instalar en un host de laboratorio, ejecutar consultas sólo lectura para software, usuarios, procesos o ajustes, programar consultas aprobadas, y cobertura de documentos.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.5 OpenSCAP

Propósito: Evaluación de configuración de Linux. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Seleccione un perfil apropiado, escanear un sistema de laboratorio, validar los resultados manualmente, registrar excepciones, remediar, y cambiar.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.6 Greenbone Community Edition

Objetivo: Gestión de la vulnerabilidad. Proyecto oficial: [ejecutado]Greenbone Community Edition (10)(<https://greenbone.github.io/docs/latest/>)

Comenzar rápido seguro: Autorizar objetivos, actualizar los piensos, realizar escaneos de laboratorio autenticados, validar la cobertura y los hallazgos, asignar la remediación y cambiar.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.7 Nmap

Propósito: Activo y descubrimiento de servicio. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Usar sólo en rangos autorizados; empezar con un escaneo de servicio limitado, comparar resultados con inventario, investigar desconocidos, y retener comando y alcance.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.8 Trivy

Propósito: Código, imagen, dependencia, secreto y análisis de configuración. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escanear un repositorio de prueba o imagen de contenedor, validar hallazgos, suprimir sólo con aprobación y razón, fijar y rescann.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.9 OWASP ZAP

Propósito: Pruebas de aplicación web autorizadas. Proyecto oficial: [Seguido] (<https://www.zaproxy.org/>)

Comenzar rápido seguro: Proxy una aplicación de entrenamiento, arrastrar pasivamente, utilizar el escaneo activo sólo con aprobación escrita, validar resultados y registrar la remediación.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.10 Keycloak

Objetivo: Identidad, MFA, roles y registros. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear un reino de laboratorio, usuarios, grupos, roles de menor privilegio, MFA, configuración de sesión y eventos; pruebas de unión, mudanza y casos de licencia.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.11 DefectoDojo

Propósito: Encontrar ingesta y remediación. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Importar resultados de escáner seguros, cuidadosamente deduplicar, asignar propietarios, establecer plazos basados en el riesgo, adjuntar pruebas, y cerrar sólo después de la prueba.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.12 AIDE

Propósito: Monitoreo de la integridad de archivos. Proyecto oficial: [ejecutar](#)

Inicio rápido seguro: Crear una línea de referencia en un host de laboratorio, hacer un cambio de archivo autorizado, ejecutar un cheque, investigar la diferencia y proteger la base de referencia.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.13 Lynis

Propósito: Auditoría de seguridad de Linux. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Auditoría de un anfitrión de laboratorio, revisión de sugerencias contra el alcance y el riesgo, decisiones de documentos, remediar elementos seleccionados y repetir.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

22.14 Open Policy Agent

Propósito: Política como código. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escribir una pequeña regla de laboratorio, probar los insumos permitidos y negados, ver la política y las pruebas, y preservar los resultados como evidencia de apoyo.

Pruebas: alcance aprobado, configuración, versión, cobertura, resultados, revisión, excepción, remediación y retest. Protege credenciales, registros, informes y copias de seguridad.

23. Manual del SGSI para gerentes

Las preguntas, el tablero, la propiedad y los administradores de decisiones deben controlar.

¿El alcance del ISMS sigue alineado con la estrategia, los servicios, las ubicaciones, los proveedores, el uso de la nube, las personas y los flujos de datos?

¿Qué cambió en el contexto, las partes interesadas, las obligaciones legales, las amenazas, la tecnología o la relevancia climática?

¿Son fiables los criterios de riesgo y los propietarios aprueban explícitamente el tratamiento y el riesgo residual?

¿El SoA coincide con la implementación del control real y las acciones abiertas?

¿Son objetivos y métricas que producen decisiones en lugar de paneles decorativos?

¿Se han intensificado los incidentes, las conclusiones de las auditorías, las excepciones, las medidas atrasadas y los fallos repetidos?

¿El examen interno de auditoría y gestión tiene suficiente independencia, competencia, tiempo y pruebas?

¿Son exactas las reclamaciones de certificación, alcance, acreditación y declaraciones de clientes?

Area | ** Cuestión del personal**

|
..... | | Contexto y alcance | ¿Hay límites, dependencias, partes y cambios actuales? Verde / Amarillo / Rojo | ¿Son coherentes los criterios y las decisiones del propietario oportunas? Verde / Amarillo / Rojo | | SoA y controles | ¿Está alineada la selección,

el estado y la evidencia? Verde / Amarillo / Rojo — Rendimiento | Do objectives, metrics, incidents, and trends drive action? Verde / Amarillo / Rojo | Proveedores | ¿Se controlan riesgos, responsabilidad, monitoreo, incidentes y salidas? Verde / Amarillo / Rojo TENCIÓN ANTERIOR ¿Son las auditorías objetivas y las conclusiones corregidas con eficacia? Verde / Amarillo / Rojo | Mejora ¿Son las causas profundas, la recurrencia y las lecciones abordadas? Verde / Amarillo / Rojo | Silencioso Certificación | ¿Son las reclamaciones alcances, actuales y compatibles? Verde / Amarillo / Rojo

24. Junior Analyst Career Guide

Una ruta práctica hacia ISMS, GRC, riesgo, auditoría y cumplimiento.

■img src="media/image9.png" estilo="width:6.15in;height:3.075in" alt="Aprende el sistema, requisitos de mapa, evidencia de prueba, reporte claramente y construya una cartera honesta".

Figura 9. Vía analista Junior ISO 27001

Junior GRC Analista

Analista de Cumplimiento ISO 27001

Analista de Controles de Seguridad

ISMS Coordinator

Análisis de riesgos

Internal Audit Associate

Third-Party Risk Analyst

Análisis de la seguridad

24.1 Típico trabajo junior

- Mantener el alcance, activo, obligación, proveedor, riesgo, control, SoA, evidencia, hallazgo y registros de acción.
- Reunir pruebas sin cambiar los registros de fuentes y validar la integridad.
- Mapa de riesgos y requisitos para controles, propietarios, procedimientos, sistemas y pruebas.
- Prueba de muestras de acceso, cambio, vulnerabilidad, incidencia, respaldo, proveedor, conciencia, control físico y continuidad.
- Apoyar auditorías internas, exámenes de gestión, métricas, acciones correctivas y preparación de certificación.
- Escribir conclusiones fácticas y revelar muestreo, alcance y limitaciones de evidencia.
- Proteger información confidencial y permanecer dentro de la autorización.

24.2 Valor de los empleadores de habilidades

|** | |... | TENIDOS conceptos ISMS | Explicar cláusulas 4-10 y mejora continua Ø Riesgo | Construir un registro y un plan de tratamiento consistentes – SoA – Justificar las selecciones, exclusiones, estado y evidencia TENER Evidencia prueba | Definir poblaciones, muestras, procedimientos, excepciones y retests | – Alfabetización técnica | Interpretar identidad, nube, registro, vulnerabilidad, respaldo y evidencia de configuración TEN Comunicación | Escribe conclusiones, acciones y resúmenes de gestión TEN ética ANTE Utilizar datos sintéticos, sistemas autorizados y afirmaciones honestas

25. Laboratorio Ficcional y Portfolio

Un entorno de prácticas seguras utilizando datos sintéticos y sistemas de laboratorio autorizados.

- La regla del laboratorio* Utilice una organización ficticia, datos sintéticos, sistemas aislados y herramientas que está autorizado para operar. No pretenda que un proyecto de cartera sea una certificación real o una auditoría cliente. | |.
- 1. Crear una empresa ficticia con dos productos, un servicio en la nube, una fuerza de trabajo remota y tres proveedores.
- 2. Escribir un análisis de contexto de una página, registro de partes interesadas, determinación de la relación climática y declaración de alcance.
- 3. Crear criterios de riesgo y un registro de riesgo de diez escenarios con propietarios y decisiones de tratamiento.
- 4. Crear un plan de tratamiento y SoA que aborde todos los 93 controles del anexo A con justificaciones concisas y estado de aplicación honesto.
- 5. Elaborar políticas, procedimientos, objetivos, métricas, registros de activos y proveedores, registros de capacitación, registros de incidentes y ejercicios de continuidad.
- 6. Utilizar algunas herramientas de código abierto en laboratorios aislados y capturar el alcance, la configuración, los resultados, la validación, la remediación y la prueba.
- 7. Diseñar y ejecutar un plan de auditoría interna contra cláusulas y controles seleccionados.
- 8. Escribir dos noconformidades, registros de raíz, acciones correctivas y pruebas de eficacia.
- 9. Crear minutos de revisión de gestión que muestren insumos, decisiones, propietarios, recursos y plazos.
- 10. Publicar sólo artefactos sintéticos y sanitarios con una clara declaración de limitaciones.

Portfolio artifact | Lo que demuestra tención

|... | – Contexto, partes, alcance | Cláusula 4 razonamiento y límites tención método de riesgo, registro, tratamiento confidencialidad Cláusula 6 y responsabilidad de riesgo Silencioso Declaración de aplicabilidad Silencioso documento de trabajo de la prueba de control | Evidencia, muestreo, excepción y conclusión – Programa de auditoría interna, plan, criterios, informe, y seguimiento – Gestión-revisión minutos | Evaluación y decisiones Liderazgo | Correctivo-acción récord | Causa raíz y eficacia – Herramienta de prueba memo – Alfabetización técnica y limitaciones

26. Plan de aprendizaje de 30 días

Un calendario centrado para la creación de capacidad útil de nivel junior.

Días

1-5

Ø 6–10 tención Criterios de riesgo, escenarios, evaluación, tratamiento, aceptación TEN 11–14 | ANEXO Temas y Declaración de Aplicabilidad | Completa ficción SoA | TEN 15–18 | Políticas, competencia, comunicación, control de documentos, operaciones | Índice de pruebas y tres procedimientos de muestra | TEN 19–22 TENIDA métricas, monitoreo, auditoría interna, revisión de la gestión | hoja métrica, plan de auditoría, agenda de revisión ANTE | 23–25 | Noconformidad, causa raíz, acción correctiva, mejora Silencioso Dos registros de hallazgo y acción correctiva TEN 26–28 | Laboratorios autorizados de herramientas de código abierto Dos pruebas y memos de retest | 29–30 | Portfolio cleanup and interview practice

27. Preparación de entrevistas

- Respuestas claras, escenarios prácticos y preguntas para el empleador.*

27.1 ¿Qué es un ISMS?

Un sistema de gestión para controlar el riesgo de seguridad de la información mediante liderazgo, planificación, operación, evaluación y mejora continua.

27.2 ISO 27001 versus 27002?

27001 contiene requisitos certificables de ISMS; 27002 proporciona orientación de control detallada y no es en sí mismo un estándar de certificación.

27.3 ¿Qué es el SoA?

A controlled record of necessary controls, Annex A inclusion or exclusion justification, and implementation status, linked to treatment and evidence.

27.4 ¿Todos los controles del Anexo A son obligatorios?

La organización debe utilizar el Anexo A como verificación de referencia y justificar decisiones. Los controles necesarios siguen el tratamiento y las obligaciones de riesgo; también pueden requerirse otros controles.

27.5 ¿Cómo prueba un control?

Definir los criterios y el alcance, validar la población, muestras por riesgo, inspeccionar y repercutir pruebas, excepciones de documentos y reprobación la corrección.

27.6 ¿Qué es una no conformidad?

No cumplir con un requisito. Se requiere corrección, evaluación de causas, acción adecuada y examen de eficacia.

27.7 ¿Qué cambió en 2024?

La enmienda exige una consideración explícita de la pertinencia del cambio climático en el contexto y observa que las partes interesadas pueden tener requisitos relacionados con el clima.

27.8 ¿Qué puede concluir un analista junior con seguridad?

Los hechos estatales respaldados por pruebas y alcance definidos, revelan limitaciones y evitan reclamar auditor o autoridad de certificación.

27.9 Preguntas para hacer al empleador

- ¿Cuál es el alcance de ISMS certificado o previsto?
- ¿Quién posee la aceptación del riesgo y el SoA?
- ¿Cómo se producen y validan las poblaciones de pruebas?
- ¿Qué sistemas gestionan riesgos, controles, proveedores, hallazgos y acciones correctivas?
- ¿Cómo se mantiene la independencia del auditor interno?
- ¿Con qué equipos técnicos trabajarán?
- ¿Cómo se revisan y entrenan las conclusiones junior?

28. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos importantes y puntos de partida autorizados.*

28.1 Registro de riesgo mínimo

**

Identificación de riesgo y dueño de la vida | Objetivo / activo | “El evento de la amenaza y la condición de vida” “Consequence” Los controles existentes en la vida son válidos. “La probabilidad y el impacto en la vida” El riesgo actual es válido para siempre. El dueño de la acción y el tratamiento de la vida ha estado en la vida. “El riesgo residual y la aceptación...” , la fecha de revisión de la vida, es la siguiente.

28.2 Documentos de prueba de control

|** | |. | Criterios y control de la vida “Escopia y período de vida” “Principal y sistemas de vida” · Population and completeness check H
“Sensacionalidad y racionalidad” El procedimiento de detención se llevó a cabo en la vida.
Evidencia inspeccionada, inspeccionada. Excepciones sobre la vida “Conclusión y limitación de la vida” Corrección y prueba de vida

28.3 Glosario

|** | |... | | ANEXO A TENCION Conjunto de referencia de 93 controles de seguridad de la información en ISO/IEC 27001:2022. | TEN CIA | Confidencialidad, integridad y disponibilidad. Silencioso Conformity | Fulfillment of a requirement. | Control | Medición que modifica o mantiene el riesgo. | Acción Correctiva | Acción frente a la causa de una no conformidad para prevenir la recurrencia. | Información documentada | Información que la organización debe controlar y mantener o retener. | Parte interesada | Persona u organización que puede afectar, ser afectada por, o percibirse afectada por una decisión o actividad. | | ISMS | Sistema de gestión de la seguridad de la información. | Noconformidad Silencioso para cumplir con un requisito. | | Riesgo residual | El riesgo permanece después del tratamiento. Silencioso propietario | Persona o entidad responsable y autorizado para gestionar un riesgo. | SoA Silencioso Declaración de Aplicabilidad. | tención Gestión superior | Persona o grupo dirigiendo y controlando la organización al más alto nivel dentro del alcance. —

28.4 Índice de asunto

Subjeto** | ————— | | ANEXO A controls | 13-16 Silencioso en la auditoría Silencioso Certificación | 21 | | Cambio climático | | Acción correctiva | | Evidencia | 5, 18 Silenciosas partes interesadas Silencioso analista junior Silencioso examen de la gestión TENIDA Metrics TENENCIA 11, 18 | Herramientas de código abierto | 22 | Silencioso evaluación y tratamiento de los riesgos Silencioso en la vida útil 2, 6 Silencioso Declaración de aplicabilidad Silenciosos Proveedores | 13, 18, 23 |

28.5 Referencias oficiales

[](<https://www.iso.org/standard/27001>)

[](<https://www.iso.org/standard/88435.html>)

[](<https://www.iso.org/standard/75652.html>)

Nota de cambio climático

Según la descripción de la certificación efectuada

[](<https://www.iso.org/standard/iso-iec-27000-family>)

Recuerdo final: Adquirir o acceder legalmente a las normas oficiales antes de su aplicación o evaluación. Confirme las ediciones, enmiendas, acreditación, alcance de certificación, requisitos legales, contratos, tecnología, amenazas y cambio organizativo. |

|. |